

MANUAL VENDOR RISK ASSESSMENT

Vendor: Discovery Group

Date: 22 August 2026

Assessor: Motheo Sekano

1. EXECUTIVE SUMMARY

Discovery Group is a diversified financial services and health insurance provider operating a shared-value ecosystem. Due to the nature of their operations, they process high volumes of sensitive financial data and Special Personal Information (health metrics and medical aid dependencies).

Overall Impression: While the public-facing privacy policy demonstrates a high-level commitment to data protection, it lacks the specific technical, organizational, and governance control details required for a comprehensive third-party risk assessment.

2. POPIA COMPLIANCE ANALYSIS

Section 19 (Security Safeguards):

The policy states the use of "commercially acceptable means" but fails to specify the technical and organizational safeguards (encryption at rest/in transit, strict access controls) applied to Special Personal Information. This represents a potential gap in demonstrating compliance with POPIA Section 19(1)(a) and 19(1)(b).

Section 22 (Security Compromise Notification):

The policy lacks an explicit commitment to notifying the Information Regulator and affected data subjects in the event of a security compromise. Furthermore, it omits any defined timeframe ("as soon as reasonably possible") for such notification, posing a compliance risk under POPIA Section 22.

3. ISO/IEC 27001:2022 ANALYSIS

Annex A.5.19 (Information security in supplier relationships):

Finding: The public documentation contains no mention of supplier security assessment processes, vendor risk management frameworks, or requirements for third parties to adhere to information security standards.

4. KING IV ANALYSIS

Principle 12 (Technology and Information Governance):

The policy does not articulate how technology and information governance are overseen by the governing body (Board), nor does it reference alignment with national cybersecurity frameworks, which is a core expectation of King IV Principle 12 for entities handling critical data.

5. RISK SCORE & RECOMMENDATION

Risk Score: 8/10 (High Risk)

The vendor processes high volumes of Special Personal Information and financial data, but the public policy lacks explicit evidence of robust security controls, breach notification SLAs, or third-party risk management.

Recommendation:

Do not onboard as a data processor until supplementary evidence is provided. Prior to contract signing, formally request the following from Discovery Group's security team:

1. A detailed Information Security Policy outlining technical safeguards.
2. Their Incident Response Plan, specifically highlighting breach notification SLAs.
3. The latest independent security audit report (ISO 27001 certification or SOC 2 Type II report).